



ICT Patch and Vulnerability Management Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	4
2. Functional Scope and Target Groups	5
2.1. Functional scope of applicability	5
2.2. Target groups	5
2.3. Transition period	6
3. Definitions	7
3.1. Requirements	7
3.2. Explanation of requirements and key definitions	8
4. Requirements	9
4.1. Vulnerability Management	9
4.2. Patch Management	34
5. Roles and Responsibilities	40
5.1. Creator	40
5.2. Guideline Owner	40
6. Appendix	41
6.1. Contact Information	41
6.2. Document History	41
6.3. Related Written Rules	41
6.4. Abbreviations	42

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The ICT Patch and Vulnerability Management Guideline (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Identify	4. Establish an ICT risk management process and perform ICT risk assessment on a regular basis and in the event of major changes, considering threats and vulnerabilities covering different IT assets (e.g. applications) and Non-IT assets (e.g. buildings, rooms) in a consistent way taking into consideration asset-specific differences in the assessment approach.	4.2
Protect	1. Design and implement ICT risk management control requirements to achieve the protection goals and integrating them to the ICT Written Rules framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management, AI, IDP & NCLC¹, data	4.3

¹ IDP refers to Individual Data Processing, and NCLC refers to No-Code/Low-Code solutions.

	management and other controls addressing poor administration and human error risks.	
Detect	1. Define, implement, monitor, and regularly test detection processes and mechanisms to promptly detect anomalous activities including network performance issues and ICT-related incidents, and identify potential material single points of failure.	4.4
Detect	2. Put in place sufficient capabilities to monitor user activity, the occurrence of anomalous events, in particular cyber-attacks.	4.4

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy.

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG and/or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; or any other area that owns ICT Patch and Vulnerability Management topic

Table 2: Scope

2.2. Target groups

Within the scope of the current ICT Patch and Vulnerability Management Guideline below is addressed the list of applicable target groups and operation areas²:

Target group	Key message
ICT Risk Oversight	To oversee the development, implementation, and enforcement of ICT Patch and Vulnerability Management policies and ensure alignment with broader cybersecurity strategies.
ICT Operational Management	To implement and manage ICT Patch and Vulnerability Management measures and other protective technologies.
Business Management	To lead and direct actions (incl. ICT-risks). To be accountable for the management of ICT-risks affecting their business function or process. To decide on risk treatment (accept, transfer, avoid or mitigate the risk).
Management Body	To endorse and provide the necessary resources for ICT Patch and Vulnerability Management initiatives and understand the implications of vulnerabilities of all infrastructure types.

Table 3: Target groups

² For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

4. Requirements

4.1. Vulnerability Management

ID: 1 (version 2.0)	General requirements for vulnerability management
1 DOR.ICT.PVM.GEN.001	It must be ensured that the legal entity is capable of adequately handling vulnerabilities and that a dedicated test program is in place for this purpose.
1.1 DOR.ICT.PVM.GEN.002	Vulnerability management procedures must be developed, documented and implemented to ensure that vulnerabilities are identified on a timely basis, assessed accordingly, prioritized, reported, tracked, and resolved. Asset-Types: Business Process Key References: DORA RTS RMF A10.1
1.2 DOR.ICT.PVM.GEN.003	A sound and comprehensive testing program, encompassing both fundamental and advanced tests, must be established, maintained, and reviewed to identify weaknesses in the digital operational resilience is defined in ID 21 of the ICT Risk Management Guideline. This Guideline provides the operational specifications for the testing types assigned to it under that programme Asset-Types: Business Process Key References: DORA 2022/2554 A.24.1
1.3 DOR.ICT.PVM.GEN.004	The testing program must follow a risk-based approach, considering the proportionality principle, the evolving ICT risk landscape, any specific risks to which the legal entity or asset is or may be exposed, the criticality of information assets with regard to any of the protection goals and services provided, and other relevant factors such as the overall risk profile or the involvement of ICT third-party service providers. Asset-Types: Business Process Key References: DORA 2022/2554 A.24.1
1.4 DOR.ICT.PVM.GEN.005	The testing program must include assessments, tests, methodologies, practices, and tools that are to be applied to both fundamental and advanced tests, which must be performed for all ICT Systems, including applications, supporting critical or important functions, at least annually. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.4.2, A.24.6
1.5 DOR.ICT.PVM.GEN.006	For both fundamental and advanced tests, the testers must be independent and, if internal testers are used, they must have sufficient resources at their disposal and conflicts of interest must be avoided. Asset-Types: Business Process Key References: DORA 2022/2554 A.24.4
1.6 DOR.ICT.PVM.GEN.007	Comprehensive procedures for the identification, prioritization and remediation of issues discovered during testing must be in place, including

	validation procedures to ensure that all identified vulnerabilities, deficiencies or other issues like non-compliances³ are resolved. Asset-Types: Business Process Key References: DORA 2022/2554 A.24.5
1.7 DOR.ICT.PVM.GEN.008	A list of relevant contacts involved in the detection and monitoring of cyber threats and anomalous activities, as well as in vulnerability management, must be established. Asset-Types: Business Process Key References: DORA RTS RMF A.22.b)
1.8 DOR.ICT.PVM.GEN.009	Results of all testing activities conducted under this Guideline must be reported to the DORT Programme owner for consolidation into the programme-level register and management body reporting in accordance with ID 21 of the ICT Risk Management Guideline. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(1)

ID: 2 (version 2.0)	Vulnerability management of ICT third-party service providers
2 DOR.ICT.PVM.3PT.001	It must be ensured that risks resulting from vulnerabilities of ICT third-party service providers are also included in the legal entity's vulnerability management.
2.1 DOR.ICT.PVM.3PT.002	The legal entity must verify that ICT-third party service providers manage vulnerabilities related to the ICT services provided. Asset-Types: Business Process Key References: DORA RTS RMF A.10.2c)
2.2 DOR.ICT.PVM.3PT.003	The legal entity must verify that those service providers report at least critical vulnerabilities, statistics, and trends to it in a timely manner and request the ICT third-party service provider to investigate vulnerabilities, determine their root causes, and implement appropriate mitigation actions when such vulnerabilities are identified and reported. Asset-Types: Business Process Key References: DORA RTS RMF A.10.2c)
2.3 DOR.ICT.PVM.3PT.004	When using cloud services, the cloud service provider's responsibilities for technical vulnerability management must be part of the cloud service contractual agreement (incl. processes for reporting the cloud service provider's actions relating to technical vulnerabilities). Asset-Types: Business Process Key References: DORA RTS RMF A.10.2c)

ID: 3 (version 2.0)	Threat Intelligence
------------------------	---------------------

³ Non-compliances are to be understood as vulnerabilities.

3 DOR.ICT.PVM.LEU.001	It must be ensured that the legal entity is always kept up to date with regard to vulnerabilities and emerging threats.
3.1 DOR.ICT.PVM.LEU.002	To raise and maintain awareness of vulnerabilities and existing or emerging threats, relevant and trusted sources of information must be regularly identified, collected, analyzed and kept up to date. Asset-Types: Business Process Key References: DORA RTS RMF A.10.2a)
3.2 DOR.ICT.PVM.LEU.003	Threat intelligence should include up-to-date information about threats and attacks on strategic, tactical, and operational levels: - Exchange of high-level information about the changing threat landscape (strategic level) - Information about attacker methodologies, tools and technologies involved (tactical level) Details about specific attacks, including technical indicators (operational level) Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.7
3.3 DOR.ICT.PVM.LEU.004	Internal and external potential threats must be collected, monitored and analyzed, taking into account attack scenarios commonly used by threat actors and scenarios based on threat intelligence. Asset-Types: Business Process Key References: DORA RTS RMF A.23.2a.ii)
3.4 DOR.ICT.PVM.LEU.005	Capabilities and staff must be in place to perform threat intelligence and analyze the impact of vulnerabilities, cyber threats and attacks on the digital operational resilience (DOR). Asset-Types: Business Process Key References: DORA 2022/2554 A.13.1; DORA RTS RMF A.10.2a), A.23.2a.ii), ISO/IEC 27002:2022 A.5.7; MAS TRMG 4.1.4, 4.2.1, 4.3.1, 4.4.1, 12.1.2

ID: 4 (version 2.0)	Identification of vulnerabilities through fundamental and advanced tests
4 DOR.ICT.PVM.VID.001	It must be ensured that both fundamental and advanced tests are properly performed to identify and evaluate vulnerabilities.
4.1 DOR.ICT.PVM.VID.002	Vulnerability identification measures must be defined and implemented for IT Assets of the legal entity in a risk-based approach that utilizes adequate assessment and test frequencies and an adequate depth and completeness of assessment and test results per Segregation Area, system criticality with regard to any of the protection goals or system purpose. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.8
4.2 DOR.ICT.PVM.VID.003	To identify and evaluate vulnerabilities, security assessments and tests must be conducted regularly as part of the fundamental tests and, if necessary, additionally on an ad-hoc basis. The security assessment and test type (vulnerability assessments and scans, external attack surface scans, source internal

	code review and open-source analysis, network security assessments, gap analyses, physical security reviews, questionnaires and scanning software solutions, scenario-based tests, compatibility testing, performance testing, end-to-end testing and penetration testing) must be chosen based on the information asset classification with regard to any of the protection goals, asset type, exposure and the Segregation Area. For internet exposed assets, external attack surface scans should be considered. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.25.1
4.3 DOR.ICT.PVM.VID.004	The vulnerability categories and assessment method as well as scope must be defined for all fundamental tests that are defined in this Guideline. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
4.4 DOR.ICT.PVM.VID.005	If adverse effects are envisioned in the Red Segregation Area, fundamental tests must generally be conducted in the Yellow Segregation Area and only be conducted in other Segregation Areas if it is not possible in the Yellow Segregation Area. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.8
4.5 DOR.ICT.PVM.VID.006	A security assessment plan must be defined to ensure that the fundamental tests of all IT Assets⁴ of the legal entity are scheduled and performed as required. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.8
4.6 DOR.ICT.PVM.VID.007	Fundamental tests must be conducted by qualified testers that are independent from the security control implementation. Asset-Types: Business Process Key References: DORA 2022/2554 A.24.4
4.7 DOR.ICT.PVM.VID.008	Appropriate guiding procedures for all fundamental and advanced tests must be defined and documented. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
4.8 DOR.ICT.PVM.VID.009	Processes for all fundamental and advanced tests must be defined, regularly monitored, and evaluated, for planning and conducting the fundamental and advanced tests to ensure asset coverage, appropriate scoping, timely completion, and reporting.

⁴ Relevant non-IT assets are addressed in the Data Center and Physical Protection Guideline in control requirement 12.

	Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
4.9 DOR.ICT.PVM.VID.010	Network security assessments must be conducted to evaluate the effectiveness of network security controls, identify misconfigurations, and detect potential vulnerabilities in the network architecture, including network segmentation, firewall rules, access controls, and network service configurations. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
4.10 DOR.ICT.PVM.VID.011	Gap analyses must be conducted to systematically identify and document deviations between the current implementation of ICT security controls and the requirements defined in the ICT Risk Management Framework, applicable regulatory requirements, and the digital operational resilience strategy. Asset-Types: Business Process Key References: ICT Risk Management Framework
4.11 DOR.ICT.PVM.VID.012	Questionnaires must be used as a structured assessment method to evaluate the ICT security posture of the legal entity and of ICT third-party service providers where direct technical testing is not feasible, in accordance with ID 2 (Vulnerability management of ICT third-party service providers). Asset-Types: Business Process Key References: DORA RTS RMF A.10.2c)

ID: 5 (version 2.0)	Penetration tests
5 DOR.ICT.PVM.PEN.001	It must be ensured that as part of the security assessments and tests, penetration tests are performed.
5.1 DOR.ICT.PVM.PEN.002	Penetration tests must be performed regularly at the defined intervals: Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.8
5.1.1 DOR.ICT.PVM.PEN.003	Penetration tests⁵ of all IT applications and their underlying infrastructure assets supporting critical (regarding confidentiality, integrity, availability, or authenticity) or important functions (CIF) and of all KRITIS-relevant assets must be conducted at least every 12 months. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.8

⁵ Penetration tests are conducted against IT applications as the primary target. Penetration testing will inherently target parts of the technology stack that support the application. This guideline uses the phrase "IT applications and their underlying infrastructure assets" to reflect this.

5.1.2 DOR.ICT.PVM.PEN.004	Penetration tests of all internet-facing IT applications and their underlying infrastructure assets must be conducted at least every 12 months. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.8
5.1.3 DOR.ICT.PVM.PEN.005	Penetration tests of all IT Applications and their underlying infrastructure assets that are critical regarding confidentiality, integrity, availability, or authenticity must be conducted at least every 12 months. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.8
5.1.4 DOR.ICT.PVM.PEN.006	Penetration tests of all other IT Applications and their underlying infrastructure assets infrastructure (that are not covered by 5.1.1.-5.1.3) must be conducted at least every 36 months. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.8
5.1.5 DOR.ICT.PVM.PEN.007	Penetration tests of all IT applications and their underlying infrastructure assets must be conducted upfront before initial deployment into the Red Segregation Area, and whenever security relevant changes are released into the Red Segregation Area. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.8
5.1.6 DOR.ICT.PVM.PEN.008	If network segments (within a network security zone) are segregated, the frequency of penetration tests must be based on the maximum criticality value (regarding confidentiality, integrity, availability, or authenticity) of the assets in the respective segregated network segment within that network security zone. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.8
5.1.7 DOR.ICT.PVM.PEN.009	If network segments (within a network security zone) are not segregated, the frequency of penetration tests for all applications within these unsegregated network segments must be determined based on the maximum criticality value (regarding confidentiality, integrity, availability, or authenticity) of the assets in the respective network segments within that network security zone. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage,

	Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.8
5.2 DOR.ICT.PVM.PEN.010	Penetration tests must be carried out by independent testers with sufficient knowledge, skills, and expertise in testing information security measures and who are not involved in the development of the information security measures. Asset-Types: Business Process Key References: DORA 2022/2554 A.24.4
5.3 DOR.ICT.PVM.PEN.011	Vendor rotation must be applied at least every 24 months. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
5.4 DOR.ICT.PVM.PEN.012	Penetration tests for software as a service (SaaS) provided by third parties must be conducted by the vendor according to contractual agreements based on the requirements for internet-facing IT applications (see above). Asset-Types: Information, SaaS, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.8
5.5 DOR.ICT.PVM.PEN.013	Type, scope, period, and results of a penetration test must be documented in a traceable manner which is comprehensible for a competent third party. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
5.6 DOR.ICT.PVM.PEN.014	All detected vulnerabilities must be transferred and addressed to a predefined structured remediation process. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
5.7 DOR.ICT.PVM.PEN.015	A combination of blackbox and greybox testing should be conducted. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8

ID: 6 (version 2.0)	Vulnerability assessments and scans
6 DOR.ICT.PVM.VAS.001	It must be ensured that as part of the security assessments and tests, vulnerability assessments and scans are performed.
6.1 DOR.ICT.PVM.VAS.002	Prior to their deployment, all IT Assets with the exception of Mobile Devices must be onboarded to the vulnerability scanning tool(s). Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.8
6.2 DOR.ICT.PVM.VAS.003	Prior to their deployment or redeployment in the Red Segregation Area, vulnerability assessments must be performed on all IT Assets and ICT services that support critical or important functions. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance,

	Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.10.2b)
6.3 DOR.ICT.PVM.VAS.004	Regular automated vulnerability scans and assessments on all relevant IT Assets must be performed, with the frequency and scope corresponding to their information classification with regards to any of the protection goals and overall risk profile of the IT Asset, however at least weekly. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.25.2

ID: 7 (version 2.0)	Source code review and open-source analysis
7 DOR.ICT.PVM.SCR.001	It must be ensured that as part of the security assessments and tests, source code reviews and open-source analysis are performed.
7.1 DOR.ICT.PVM.SCR.002	Source code review must be conducted for all source codes of IT applications before deployment in the Red Segregation Area. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance Key References: ISO 27001:2022 Cor 202203 A.8.29
7.2 DOR.ICT.PVM.SCR.003	Source code reviews must be conducted for all owned source codes of IT applications at least every 12 months. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance Key References: ISO 27001:2022 Cor 202203 A.8.29
7.3 DOR.ICT.PVM.SCR.004	Source code reviews for not owned source code of IT applications must be performed by the external vendor. Reports or confirmations must be conducted. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.29
7.4 DOR.ICT.PVM.SCR.005	The use of third-party libraries, including open-source libraries used by ICT services supporting critical or important functions, as well as ICT services developed by the legal entity or customized or specifically developed for the legal entity by ICT third-party service providers, must be monitored, also with respect to new updates, tracked and controlled. Asset-Types: Business Process Key References: DORA RTS RMF A.10.2.d)
7.5 DOR.ICT.PVM.SCR.006	For IT Assets used in the operation of ICT services that do not support critical or important functions, the use of third-party libraries, including open-source libraries, must be tracked to the extent possible.

	Asset-Types: Business Process Key References: DORA RTS RMF A.10.2.d)
--	---

ID: 8 (version 2.0)	Compliance scans
8 DOR.ICT.PVM.SCN.001	As part of the security assessments and tests, compliance scans must be conducted for IT Asset at least weekly and should be conducted on an on-going basis for End User Devices. Asset-Types: Information, Business Process, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.36

ID: 9 (version 2.0)	Bug bounty program
9 DOR.ICT.PVM.BBP.001	The legal entity should consider bug bounty programs with clearly defined rules and scope, where rewards are offered as an incentive to assist legal entities in identifying vulnerabilities in order to appropriately remediate them. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8

ID: 10 (version 2.0)	General requirements for advanced testing based on TLPT
10 DOR.ICT.PVM.TTP.001	It must be ensured that advanced tests, which mimic the tactics, techniques and procedures of real-life threat actors are carried out.
10.1 DOR.ICT.PVM.TTP.002	TLPTs must be carried out at least every three years, with the interval adjusted as requested by the competent authority. Asset-Types: Business Process Key References: DORA 2022/2554 A.26.1
10.2 DOR.ICT.PVM.TTP.003	Each TLPT must cover several critical or important functions of the legal entity and must be performed in the Red Segregation Area. Asset-Types: Business Process Key References: DORA 2022/2554 A.26.2
10.2.1 DOR.ICT.PVM.TTP.004	For this purpose, all relevant underlying ICT Systems, processes, and technologies that support these critical or important functions and ICT services, including those outsourced to third-party providers, must be identified. Asset-Types: Business Process Key References: DORA 2022/2554 A.26.2
10.2.2 DOR.ICT.PVM.TTP.005	The legal entity must assess which critical or important functions need to be covered by the TLPT, thereby determining the precise scope of the TLPT, which must then be validated by the competent authority.

	Asset-Types: Business Process Key References: DORA 2022/2554 A.26.2
--	--

ID: 11 (version 2.0)	Organizational provisions for TLPTs
11 DOR.ICT.PVM.CTL.001	It must be ensured that organizational and procedural measures are taken, and a control team lead is assigned to safeguard the proper execution of TLPTs.
11.1 DOR.ICT.PVM.CTL.002	The legal entity must appoint a control team lead responsible for the day-to-day management of the TLPT, as well as the decisions and actions of the control team. Asset-Types: Business Process Key References: DORA RTS TLPT A.4.1
11.2 DOR.ICT.PVM.CTL.003	The legal entity must establish both organizational and procedural measures to ensure the following: Asset-Types: Business Process Key References: DORA RTS TLPT A.4.2.a)
11.2.1 DOR.ICT.PVM.CTL.004	Access to information regarding a planned or ongoing TLPT is limited based on the need-to-know principle to the control team, management body, testers, threat intelligence provider, and the TLPT authority. Asset-Types: Business Process Key References: DORA RTS TLPT A.4.2.a)
11.2.2 DOR.ICT.PVM.CTL.005	The control team must consult the test managers before involving a member of the blue team in a TLPT. Asset-Types: Business Process Key References: DORA RTS TLPT A.4.2.b)
11.2.3 DOR.ICT.PVM.CTL.006	The control team must be informed of any relevant detection of the TLPT by staff members of the legal entity or third-party service providers, with the control team being responsible for the escalation of the resulting incident response, where required. Asset-Types: Business Process Key References: DORA RTS TLPT A.4.2.c)
11.2.4 DOR.ICT.PVM.CTL.007	Confidentiality agreements must be in place for the legal entity's staff involved in the TLPTs and the relevant third-party ICT service providers, testers, and threat intelligence providers. Asset-Types: Business Process Key References: DORA RTS TLPT A.4.2.d)
11.2.5 DOR.ICT.PVM.CTL.008	The control team must provide any information relating to the TLPT to the test managers on request. Asset-Types: Business Process Key References: DORA RTS TLPT A.4.2.e)
11.2.6 DOR.ICT.PVM.CTL.009	Wherever possible, parties involved in the TLPT must refer to it only by its code name. Asset-Types: Business Process Key References: DORA RTS TLPT A.4.2.f)

ID: 12 (version 2.0)	Pooled and joint TLPTs
12	It must be ensured that in the case of pooled and joint TLPTs, each legal or financial entity is itself responsible for risk management in relation to TLPTs.
12.1	When performing a joint or pooled TLPT, the control team of each legal or financial entity must: Asset-Types: Business Process Key References: DORA RTS TLPT A.6.1
12.1.1	Conduct its own risk assessment and establish its own risk management measures. Asset-Types: Business Process Key References: DORA RTS TLPT A.6.1
12.1.2	Consider aspects related to the involvement of multiple financial entities in the TLPT for the risk assessment. Asset-Types: Business Process Key References: DORA RTS TLPT A.6.2
12.1.3	Follow each of the requirements related to TLPT, including providing the remediation plan to the TLPT authority, as referred to in the control requirement for Remediation of Vulnerabilities. Asset-Types: Business Process Key References: DORA RTS TLPT A.7.1
12.2	If multiple TLPT authorities are involved in a joint or pooled TLPT, the term "TLPT authority" must be understood as referring to the leading TLPT authority. Asset-Types: Business Process Key References: DORA RTS TLPT A.7.2
12.3	If the participation of an ICT third-party service provider in the TLPT is expected to negatively impact the quality, security, or confidentiality of services provided to other customers, the legal entity and the provider must agree in writing for the provider to contract directly with an external tester allowing pooled testing. The pooled TLPT must cover the relevant ICT services supporting critical or important functions provided by the ICT third-party service provider to those financial entities. The number of financial entities participating in pooled TLPT shall be calibrated based on the complexity and type of ICT services involved. Asset-Types: Business Process Key References: DORA RTS TLPT A.7.2, DORA 2022/2554 A.26.4

ID: 13 (version 2.0)	TLPT preparation phase
13 DOR.ICT.PVM.PRP.001	During the preparation phase, it must be ensured that timelines are adhered to, specific documentation is created and made available to relevant stakeholders, and that stakeholders are involved accordingly.
13.1 DOR.ICT.PVM.PRP.002	Within three months of receiving notification from the TLPT authority that a TLPT is to be conducted, the legal entity must submit the following TLPT initiation documents to the test managers:

	- A project charter, including a high-level project plan, containing the information set out in Annex I of the DORA RTS on TLPT - The contact details of the control team lead - Information on the intended use of internal or external testers, or both - Information on the communication channels to be used during the TLPT - The code name for the TLPT Asset-Types: Business Process Key References: DORA RTS TLPT A.8.1.a)
13.2 DOR.ICT.PVM.PRP.003	After the validation of the TLPT initiation documents by the TLPT authority, a control team must be established to support the control team lead in the following tasks: - Defining communication channels and processes within the control team, as well as with the testers and threat intelligence providers, on all matters related to the TLPT - Informing the management body of the legal entity about the progress of the TLPT and the associated risks - Making decisions based on subject matter expertise throughout the TLPT - Selecting the threat intelligence provider and the external testers, internal testers, or both for the TLPT - Preparing the scope specification document Asset-Types: Business Process Key References: DORA RTS TLPT A.8.3.a)
13.3 DOR.ICT.PVM.PRP.004	The legal entity must submit a scope specification document containing all the information set out in Annex II of the RTS on TLPT to the test managers within six months of receiving notification from the TLPT authority requesting that a TLPT be carried out. The management body of the financial entity shall approve the scope specification document. Asset-Types: Business Process Key References: DORA RTS TLPT A.8.5
13.4 DOR.ICT.PVM.PRP.005	Once contracted, the control team must share the initiation documents and scope specification document with the testers and threat intelligence providers and inform them about the testing process to be followed. Asset-Types: Business Process Key References: DORA RTS TLPT A.8.7
13.5 DOR.ICT.PVM.PRP.006	The procurement or assignment of testers and threat intelligence providers must be finalized before the testing phase begins. Asset-Types: Business Process Key References: DORA RTS TLPT A.8.8

ID: 14 (version 2.0)	Risk assessment and management associated with TLPTs
14 DOR.ICT.PVM.RAM.001	It must be ensured that during the preparation phase the control team adequately assesses risks associated with TLPTs.
14.1 DOR.ICT.PVM.RAM.002	All of the following must be considered for the inclusion of critical or important functions in the scope of the TLPT: - Criticality or importance of the function and its possible impact to the financial sector and on financial stability at national and Union level - Importance of the function for the day-to-day business operations of the legal entity - Exchangeability of the function - Interdependence with other functions - Geographical location of the function - Sectoral dependence of other entities on the function - Threat intelligence concerning the function, where available Asset-Types: Business Process Key References: DORA RTS TLPT A.8.6.a)
14.2 DOR.ICT.PVM.RAM.003	The control team must consult the test managers on the TLPT risk assessment and risk management measures prior to initiating the testing phase. Additionally, they must review the risk assessment and risk management measures if the TLPT authority determines that they do not adequately address the risks of the TLPT. Asset-Types: Business Process Key References: DORA RTS TLPT A.8.9
14.3 DOR.ICT.PVM.RAM.004	The control team must at least consider the following types of risks in their risk assessment and management: - Granting the threat intelligence provider and external testers access to sensitive and confidential information - Non-compliance of the TLPT with the requirements laid out in this Guideline, including breaches of confidentiality or lack of ethical conduct - Crisis and incident escalation - Activities of the red or blue team, including risks associated with the disruption of critical activities and corruption of data due to the activities of the testers or the blue team and potential impacts on third parties - Incomplete restoration of systems affected by the TLPT Asset-Types: Business Process Key References: DORA RTS TLPT A.5.4.a)
14.4 DOR.ICT.PVM.RAM.005	Effective risk management controls must be applied, with the cooperation of ICT third-party service providers and involved parties (excluding competent authorities), to mitigate the risks of potential impact on data, damage to assets, and disruption of critical or important functions, services, or operations within the legal entity, its counterparts, or the financial sector. Asset-Types: Business Process Key References: DORA 2022/2554 A.26.5

ID: 15 (version 2.0)	Requirements for TLPT testers and threat intelligence providers
15 DOR.ICT.PVM.QUA.001	During the preparation phase, the control team must ensure that the testers contracted and involved in the TLPTs, including internal testers and threat intelligence providers, are suitably qualified.
15.1 DOR.ICT.PVM.QUA.002	Only testers, whether internal or external, that meet all the following must be used to perform the TLPTs: - Demonstration of highest suitability and reputability - Possess technical and organizational capabilities and show specific expertise in threat intelligence, penetration testing, and red team testing - Be certified by an accreditation body in a Member State or adhere to formal codes of conduct or ethical frameworks - Provide independent assurance or an audit report regarding the sound management of risks associated with conducting the TLPT, including appropriate protection of the legal entity's confidential information and redress for business risks - Be fully and duly covered by relevant professional indemnity insurances that cover risks of misconduct and negligence. Threat intelligence providers must also have such insurance Asset-Types: Business Process Key References: DORA 2022/2554 A.27.1.a)
15.2 DOR.ICT.PVM.QUA.003	If internal testers are used, all the following must additionally be fulfilled: - Internal testers must be approved by the relevant competent authority or the single public authority - The legal entity must have sufficient dedicated resources and capabilities when using internal testers, as verified by the competent TLPT authority, and must ensure that conflicts of interest are avoided throughout all phases of the TLPT, especially during the design and execution phases - Measures must be taken to ensure that using internal testers does not adversely affect the legal entity's overall defensive or resilience capabilities with respect to ICT-related incidents, or significantly impact the availability of resources devoted to ICT-related tasks during a TLPT - The threat intelligence provider must always be external - The internal testing team includes a test lead, and at least two additional members - All members of the test team have been employed by the financial entity or by an ICT intra-group service provider for the preceding 12 months; Asset-Types: Business Process Key References: DORA 2022/2554 A.27.2.a)
15.3 DOR.ICT.PVM.QUA.004	The use of internal testers must be mentioned in all the following documents: - The test initiation documents - The red team test report - The report summarizing the relevant findings of the TLPT Asset-Types: Business Process Key References: DORA RTS TLPT A.13.2.a)
15.4 DOR.ICT.PVM.QUA.005	Testers employed by an ICT intra-group service provider must be regarded as internal testers of the legal entity. Asset-Types: Business Process Key References: DORA RTS TLPT A.13.3

15.5 DOR.ICT.PVM.QUA.006	When using internal testers for TLPT, external testers must be contracted every three tests. Asset-Types: Business Process Key References: DORA 2022/2554 A.26.8
15.6 DOR.ICT.PVM.QUA.007	Contracts with external testers must ensure that the TLPT results are properly managed and that any data processing, including generation, storage, aggregation, drafting, reporting, communication, or destruction, does not introduce risks to the legal entity. Asset-Types: Business Process Key References: DORA 2022/2554 A.27.3
15.7 DOR.ICT.PVM.QUA.008	For external testers, the staff of the red team assigned to the TLPT must: - Consist of at least one manager with at least five years' experience and at least two additional testers with at least two years' experience of penetration and red team testing each - Possess a broad and suitable level of professional knowledge and skills, including understanding the legal entity's business, reconnaissance, risk management, exploit development, physical penetration, social engineering, vulnerability analysis, and adequate communication skills to clearly present the results - Have participated in a minimum of five previous penetration and red team testing engagements - Not be employed by, or provide services to, a provider that simultaneously performs blue team functions for any financial institution, ICT third-party service provider, or intragroup ICT service provider participating in the TLPT - Be separated from any employee of the same vendor who is also providing threat intelligence services to the same TLPT Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.f).i
15.8 DOR.ICT.PVM.QUA.009	The staff of the threat intelligence provider assigned to the TLPT must: - Consist of at least one manager with a minimum of five years' experience and at least one other member with at least two years' experience in threat intelligence - Possess a broad and suitable level of professional knowledge and skills, including intelligence gathering tactics, techniques and procedures, geopolitical, technical, and sectoral knowledge, and adequate communication skills to clearly present and report on the outcome of the assignment - Have participated in a minimum of three previous threat intelligence engagements involving penetration and red team testing - Not simultaneously perform blue team duties or other services that may present a conflict of interest with the legal entity, ICT third-party service provider or intragroup ICT service provider involved in the TLPT - Be separated from, and not report to, personnel from the same vendor providing external testers for the same TLPT Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.e).i
15.9 DOR.ICT.PVM.QUA.010	Both threat intelligence providers and external testers must supply copies of certifications that meet recognized market standards and demonstrate their suitability for performing their respective activities.

	Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.a)
15.10 DOR.ICT.PVM.QUA.011	External testers must provide at least five references from previous assignments related to penetration and red team testing. Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.d)
15.11 DOR.ICT.PVM.QUA.012	Threat intelligence providers must provide at least three references from previous assignments related to penetration and red team testing. Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.c)
15.12 DOR.ICT.PVM.QUA.013	Measures and safeguards must be taken to ensure the participation of ICT third-party service providers if involved in the TLPT. The legal entity remains fully responsible for compliance with this Guideline. Asset-Types: Business Process Key References: DORA 2022/2554 A.26.3
15.13 DOR.ICT.PVM.QUA.014	The control team must keep records of the documentation provided by the testers and threat intelligence providers, including their curriculum vitae, as evidence of compliance with the requirements set out in this Guideline. Asset-Types: Business Process Key References: DORA RTS TLPT A.5.3
15.14 DOR.ICT.PVM.QUA.015	External testers and threat intelligence providers that do not fulfil one or more of the relevant requirements specified in this Guideline must only be contracted in exceptional cases. In such instances, the legal entity must take and document appropriate measures to mitigate the risks associated with non-compliance with those requirements. Asset-Types: Business Process Key References: DORA RTS TLPT A.5.3
15.15 DOR.ICT.PVM.QUA.016	The control team must assess whether the threat intelligence providers and testers intended for the TLPT meet the relevant requirements, document the outcome of this assessment, and select providers based on this assessment and their risk management practices. Asset-Types: Business Process Key References: DORA RTS TLPT A.8.10
15.16 DOR.ICT.PVM.QUA.017	Before contracting threat intelligence providers and external testers, the control team must provide evidence of compliance with the relevant requirements specified in this Guideline to the test managers. Asset-Types: Business Process Key References: DORA RTS TLPT A.8.10
15.17 DOR.ICT.PVM.QUA.018	Threat intelligence providers or external testers must not be contracted if the TLPT authority determines that they do not comply with national security legislation or lack the necessary qualifications. Asset-Types: Business Process Key References: DORA RTS TLPT A.8.10

ID: 16 (version 2.0)

Threat intelligence provider

16 DOR.ICT.PVM.TIP.001	Following the approval of the scope specification document by the TLPT authority, it must be ensured during the testing phase that the threat intelligence provider provides relevant information and that appropriate scenarios are selected for the TLPT.
16.1 DOR.ICT.PVM.TIP.002	The threat intelligence provider must analyze generic and sector-specific threat intelligence, identify cyber threats and existing or potential vulnerabilities relevant to the legal entity, and collect and analyze specific, actionable, and contextualized target and threat intelligence relating to the legal entity. This must include consultation with the control team and test managers. Asset-Types: Business Process Key References: DORA RTS TLPT A.9.1
16.2 DOR.ICT.PVM.TIP.003	The threat intelligence provider must present the relevant threats and targeted threat intelligence and propose appropriate scenarios to the control team, testers, and managers. The proposed scenarios must vary in terms of the identified threat actors and associated tactics, techniques, and procedures, and must target each of the critical or important functions within the scope of the TLPT. Asset-Types: Business Process Key References: DORA RTS TLPT A.9.2
16.3 DOR.ICT.PVM.TIP.004	The control team lead must select a minimum of three scenarios to conduct the TLPT based on the following elements: - The recommendation of the threat intelligence provider and the threat-led nature of each scenario - The input provided by the test managers - The feasibility of the proposed scenarios, based on the expert judgement of the testers - The size, complexity, and overall risk profile of the legal entity, as well as the nature, scale, and complexity of its services, activities, and operations Asset-Types: Business Process Key References: DORA RTS TLPT A.9.3.a)
16.4 DOR.ICT.PVM.TIP.005	The selected scenarios must fulfil all of the following: Asset-Types: Business Process Key References: DORA RTS TLPT A.9.4
16.4.1 DOR.ICT.PVM.TIP.006	At most, only one of the selected scenarios must be non-threat-led and instead be based on a forward-looking and potentially fictitious threat, considering the expected developments in the threat landscape. Asset-Types: Business Process Key References: DORA RTS TLPT A.9.4
16.4.2 DOR.ICT.PVM.TIP.007	When performing a pooled TLPT, at least one scenario must cover relevant underlying ICT Systems, processes, and technologies of the ICT third-party service provider that support the critical or important functions within the scope of the TLPT. For a joint TLPT with an ICT intra-group service provider, the scenario must cover the ICT Systems, processes, and technologies of the intra-group service provider. Asset-Types: Business Process Key References: DORA RTS TLPT A.9.4

16.5 DOR.ICT.PVM.TIP.008	The threat intelligence provider must provide the control team with the targeted threat intelligence report, which includes the information outlined in Annex III of the RTS on TLPT and the selected scenarios. Asset-Types: Business Process Key References: DORA RTS TLPT A.9.5
16.6 DOR.ICT.PVM.TIP.009	The control team must submit the targeted threat intelligence report to the test manager for approval, and the control team lead shall be informed once the report is validated. Asset-Types: Business Process Key References: DORA RTS TLPT A.9.6

ID: 17 (version 2.0)	Red teaming
17 DOR.ICT.PVM.RED.001	During the testing phase, it must be ensured that a red team test plan is agreed upon and that the subsequent testing activities are conducted in accordance with this plan and other relevant requirements.
17.1 DOR.ICT.PVM.RED.002	Once the TLPT authority approves the targeted threat intelligence report, the testers must prepare the red team test plan, including the information outlined in Annex IV of the RTS on TLPT. They must use the approved threat intelligence report and the scope specification document as the basis for developing the attack scenarios. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.1
17.2 DOR.ICT.PVM.RED.003	The testers must consult with the control team, threat intelligence provider, and test managers on the red team test plan. This includes communication, operational and project management arrangements, preparation and use cases for activating leg-ups, as well as reporting arrangements to the control team and test managers. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.2
17.3 DOR.ICT.PVM.RED.004	The red team test plan must be approved by the control team and the TLPT authority. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.3
17.4 DOR.ICT.PVM.RED.005	Any subsequent changes to the red team test plan, including schedule, scope, target systems, or flags, must be approved by both the control team lead and the test managers. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.6
17.5 DOR.ICT.PVM.RED.006	Once the red team test plan is approved by both the control team and the TLPT authority, the testers must carry out the TLPT during the active red team testing phase. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.4
17.6 DOR.ICT.PVM.RED.007	While the active red team testing phase must be conducted for a minimum of 12 weeks, any additional duration must be proportionate to the scope of the

	TLPT and reflect the size, activity, complexity, and number of financial institutions and ICT third parties or intra-group ICT service providers involved. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.5
17.7 DOR.ICT.PVM.RED.008	The control team, threat intelligence provider, testers, and test managers must all agree on the conclusion of the active red team testing phase. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.5
17.8 DOR.ICT.PVM.RED.009	Throughout the active red team testing phase, the testers must update the control team and test managers on the status of the TLPT at least weekly. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.7
17.9 DOR.ICT.PVM.RED.010	During the entire active red team testing phase, the threat intelligence provider must be available for consultation and to provide additional threat intelligence as requested by the control team. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.7
17.10 DOR.ICT.PVM.RED.011	The control team must provide in a timely manner leg-ups, designed based on the red team test plan, to help overcome obstacles and ensure that the exercise remains within the time constraints. These leg-ups may be added or modified with the approval of the control team and the test managers. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.8
17.11 DOR.ICT.PVM.RED.012	If an employee of the legal entity or one of its ICT third-party service providers or intra-group ICT service providers discovers the testing activities, the control team, in coordination with the testers, must propose and submit measures to the test managers for validation. These measures must enable the continuation of the TLPT while maintaining its confidentiality. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.9
17.12 DOR.ICT.PVM.RED.013	Only in exceptional circumstances that pose a risk of harm to data, damage to assets, or disruption of critical or important functions, services, or operations - whether belonging to the legal entity, its ICT third-party service providers, its intra-group ICT service providers or impacting its counterparties or the financial sector - the control team lead must temporarily suspend the TLPT. As a final resort, if continuing the TLPT is impossible and with prior validation from the TLPT authority, the control team lead must proceed with a limited purple teaming exercise, whose duration counts towards the minimum 12-week active red team testing phase. Asset-Types: Business Process Key References: DORA RTS TLPT A.10.10

ID: 18 (version 2.0)	Prohibited activities
18 DOR.ICT.PVM.PRO.001	It must be ensured that the parties involved in the TLPT do not carry out any prohibited activities during the testing phase.
18.1 DOR.ICT.PVM.PRO.002	The testers and threat intelligence providers must be prohibited from the following activities: Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.i).i, A.5.2.i).ii
18.1.1 DOR.ICT.PVM.PRO.003	Unauthorized destruction of equipment and modification of information and IT Assets of the legal entity or its ICT third-party service providers. Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.i).i, A.5.2.i).ii
18.1.2 DOR.ICT.PVM.PRO.004	Intentional disruption of the continuity of critical or important functions of the legal entity. Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.i).iii
18.1.3 DOR.ICT.PVM.PRO.005	Unauthorized inclusion of ICT Systems outside the scope of the TLPT. Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.i).iv
18.1.4 DOR.ICT.PVM.PRO.006	Unauthorized disclosure of test results. Asset-Types: Business Process Key References: DORA RTS TLPT A.5.2.i).v

ID: 19 (version 2.0)	TLPT closure phase
19 DOR.ICT.PVM.CLO.001	Once the active red team testing phase has been completed, it must be ensured that the closure phase is initiated, relevant reports are submitted and required exercises are being performed.
19.1 DOR.ICT.PVM.CLO.002	At the end of the active red team testing phase, the control team lead must inform the blue team that a TLPT has taken place. The control team must then promptly provide the red team test report to the blue team and test managers. Asset-Types: Business Process Key References: DORA RTS TLPT A.11.1, A.11.3
19.2 DOR.ICT.PVM.CLO.003	Within four weeks of completing the active red team testing phase, the testers must provide the control team with a red team test report, as detailed in Annex V of the RTS on TLPT. Asset-Types: Business Process Key References: DORA RTS TLPT A.11.2
19.3 DOR.ICT.PVM.CLO.004	After getting the red team test report, and within ten weeks of finishing the active red team test phase, the blue team must give the control team a blue test report with the details specified in Annex VI of the RTS on TLPT. Asset-Types: Business Process Key References: DORA RTS TLPT A.11.4

19.4 DOR.ICT.PVM.CLO.005	The control team must promptly provide the blue team's test report to the testers and test managers. Asset-Types: Business Process Key References: DORA RTS TLPT A.11.4
19.5 DOR.ICT.PVM.CLO.006	If requested by the test managers, the red and blue team test reports must not include any sensitive information. Asset-Types: Business Process Key References: DORA RTS TLPT A.11.3
19.6 DOR.ICT.PVM.CLO.007	Within ten weeks of finishing the active red team testing phase, the blue team and testers must replay the offensive and defensive actions from the TLPT. Additionally, the control team must carry out purple teaming exercises on topics chosen by the blue team and testers, focusing on identified vulnerabilities and any issues not tested during the active red team phase. Asset-Types: Business Process Key References: DORA RTS TLPT A.11.5
19.7 DOR.ICT.PVM.CLO.008	After completing the replay and purple teaming exercises, the control team, blue team, testers, and threat intelligence providers must give feedback to each other on the TLPT process. Asset-Types: Business Process Key References: DORA RTS TLPT A.11.6
19.8 DOR.ICT.PVM.CLO.009	After the TLPT authority informs the control team lead that the blue and red team test reports are satisfactory, the legal entity and any external testers must submit a summary report to the TLPT authority and the competent authority, if different, within eight weeks. This report must include the TLPT findings, as stated in Annex VII of the RTS on TLPT, remediation plans, as outlined in the control requirement Remediation of vulnerabilities, and documentation showing the TLPT was conducted properly. Asset-Types: Business Process Key References: DORA RTS TLPT A.11.7, A.26.6, A.26.7

ID: 20 (version 2.0)	Restoration procedures
20 DOR.ICT.PVM.REC.001	Once the active red team testing phase has been completed, it must be ensured that the recovery procedures are carried out.
20.1 DOR.ICT.PVM.REC.002	At the end of the testing activities, the testers and threat intelligence providers must carry out restoration procedures. These procedures must include securely deleting compromised passwords, credentials, and other secret keys, securely communicating compromised accounts to the legal entity, and securely handling the collection, storage, management, and disposal of collected data. Asset-Types: Business Process Key References: DORA RTS TLPT A.5.3.g)
20.2 DOR.ICT.PVM.REC.003	Additionally, testers must perform the following restoration procedures: - Deactivating command and control - Scope and date kill switch(es) - Removing backdoors and other malware

	- Notifying relevant parties of potential breaches - Procedures for future restoration of backups that may contain malware or tools installed during the test - Monitoring blue team activities and informing the control team of any detections Asset-Types: Business Process Key References: DORA RTS TLPT A.5.3.h).i
--	--

ID: 21 (version 2.0)	Evaluation of vulnerabilities
21 DOR.ICT.PVM.EVL.001	It must be ensured that identified vulnerabilities and associated risks are carefully and appropriately evaluated.
21.1 DOR.ICT.PVM.EVL.002	The severity and risks associated with detected vulnerabilities must be determined without undue delay after detection. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
21.2 DOR.ICT.PVM.EVL.003	Priority of the remediation activities for each validated vulnerability must be determined by considering associated risks. To make a consistent and informed decision on priority, the vulnerability item priority must be assessed as follows: Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
21.2.1 DOR.ICT.PVM.EVL.004	The output provided by scanners must be normalized and a DBG priority must be determined by additionally taking into account the exposure and criticality with regard to any of the protection goals of the asset. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
21.2.2 DOR.ICT.PVM.EVL.005	The output of a quantitative scoring model must be mapped to the Vulnerability Item Priority, and the mapping must be approved by the 2nd LoD of the legal entity. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
21.3 DOR.ICT.PVM.EVL.006	Zero-day vulnerabilities must be evaluated without undue delay, prioritized based on their exploitability, and timely treated through appropriate risk-based counter measures. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8

ID: 22 (version 2.0)	Reporting of vulnerabilities
22 DOR.ICT.PVM.REP.001	It must be ensured that identified vulnerabilities are reported in a timely and appropriate manner to all relevant stakeholders.
22.1 DOR.ICT.PVM.REP.002	Regular reporting frequency must be defined; vulnerabilities classified as “high” or above (comparable with high or above in CVSS) must immediately be reported to the respective IT Asset Owners and Information Owner. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
22.2 DOR.ICT.PVM.REP.003	The vulnerabilities’ risks and risk values must be included in the report. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
22.3 DOR.ICT.PVM.REP.004	For an efficient reporting scheme, regular reporting and ad-hoc reporting must be in place.

	Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
22.4 DOR.ICT.PVM.REP.005	Status of vulnerabilities must be regularly reported to the IT Asset Owners, at least once a month. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
22.5 DOR.ICT.PVM.REP.006	Total vulnerability landscape must be regularly reported to 1st LoD, DBAG CISO and LE CISOs, at least once a month. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
22.6 DOR.ICT.PVM.REP.007	Ad-hoc reporting must be used to inform DBAG CISO, LE CISOs of the affected LEs and IT Asset Owners about emergency and critical vulnerabilities without undue delay. Affected Information Owners and CERT (optional) must be informed about critical and emergency vulnerabilities without undue delay. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
22.7 DOR.ICT.PVM.REP.008	All vulnerabilities identified in fundamental and advanced tests must be reported to the IT Asset owners, to DBAG CISO and affected LE CISOs latest two weeks after assessment completion. In case the affected IT Asset Owners cannot be identified within this timeline, the reporting timeline to these IT Asset Owners can be prolonged. In addition, affected Information Owners and CERT (optional) must be informed about critical and emergency vulnerabilities. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
22.8 DOR.ICT.PVM.REP.009	The red team test report must be shared with DBAG CISO and LE CISOs of the affected LEs in due course and in the event no CISO is appointed, it must be shared with the 2 nd LoD. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
22.9 DOR.ICT.PVM.REP.010	Procedures for the responsible disclosure of vulnerabilities to clients, counterparties and to the public must be established. Asset-Types: Business Process Key References: DORA RTS RMF A.10.2.e)

ID: 23 (version 2.0)	Remediation of vulnerabilities
23 DOR.ICT.PVM.REM.001	It must be ensured that identified vulnerabilities are treated in an appropriate and prioritized manner.
23.1 DOR.ICT.PVM.REM.002	The vulnerabilities must be remediated according to the vulnerability item priority. The timelines for remediation (upon detection) and vulnerability item priority must be: - Emergency: All critical vulnerabilities that are reported to and stated as “emergency action required” by CERT are defined as emergency vulnerabilities. Classification criteria for vulnerability item priority

	emergency are defined in control requirement ID 30: Without undue delay - Critical: DBG score 9.0 - 10.0; max. 32 calendar days - High: DBG score 7.0 - 8.9; max. 77 calendar days - Medium: DBG score 4.0 - 6.9; max. 180 calendar days - Low: DBG score 0.0 - 3.9; max. 360 calendar days Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
23.2 DOR.ICT.PVM.REM.003	In case the remediation activities require changes on IT Assets of the legal entity, patch management as part of the change management process must be followed, irrespective whether the patch is being delivered from a vendor or development team. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.8
23.3 DOR.ICT.PVM.REM.004	A process must be defined and documented for handling requests to extend prescribed remediation timelines. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
23.4 DOR.ICT.PVM.REM.005	Use cases for an exception process must be documented and defined. The Information Owners of the legal entities must approve the criteria. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
23.5 DOR.ICT.PVM.REM.006	Vulnerabilities that cannot be remediated must be subject to compensating controls which must follow a risk-based approach and must be documented. The residual risk must be calculated. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.8
23.6 DOR.ICT.PVM.REM.007	Remediation plans, as specified in the closure phase control requirement for TLPTs, must include all of the following for each finding identified within the TLPT: - A description of the identified deficiencies - A description of the proposed remediation measures, their prioritization and estimated completion, including, where appropriate, actions to improve identification, protection, detection, and response capabilities - A root cause analysis - The personnel or functions of the legal entity responsible for implementing the proposed remediation or improvement - The risks involved in not implementing the remediation measures and, where relevant, the risks involved in implementing such measures Asset-Types: Business Process Key References: DORA RTS TLPT A.12.2a)

ID: 24 (version 2.0)	Information sharing
24 DOR.ICT.PVM.ISA.001	The legal entity should participate in information sharing arrangements with other trustworthy financial entities.
24.1 DOR.ICT.PVM.ISA.002	The legal entity should share cyber threat information and intelligence, including indicators of compromise, tactics, techniques and procedures, cyber security alerts and configuration tools, with other financial entities, provided that such sharing: - Enhances the digital operational resilience of the financial entities by raising awareness of cyber threats, limiting, or impeding the ability of cyber threats to propagate, and supporting defensive capabilities, threat detection techniques, mitigation strategies, or response and recovery phases - Is conducted within trusted communities of financial entities - Is implemented through information sharing arrangements that protect the sensitivity of the information exchanged and are governed by codes of conduct that fully respect business confidentiality and the protection of personal data Asset-Types: Business Process Key References: DORA 2022/2554 A.45.1.a)
24.2 DOR.ICT.PVM.ISA.003	When participating in information sharing arrangements, the information sharing arrangements must specify conditions for participation and, where appropriate, details of the inclusion of public authorities and the capacity in which they may be involved. The arrangements must also outline the involvement of ICT third-party service providers and the operational aspects, including the use of dedicated IT platforms. Asset-Types: Business Process Key References: DORA 2022/2554 A.45.2
24.3 DOR.ICT.PVM.ISA.004	When participating in information sharing arrangements, upon validation or cessation of membership, the legal entity must notify the competent authority. Asset-Types: Business Process Key References: DORA 2022/2554 A.45.3

4.2. Patch Management

ID: 25 (version 2.0)	Patch management
25 DOR.ICT.PVM.EFF.001	It must be ensured that proper patch management is in place to handle patches effectively.
25.1 DOR.ICT.PVM.EFF.002	Patch management procedures must be developed, documented, and implemented. Asset-Types: Business Process Key References: DORA RTS RMF A.10.3
25.2 DOR.ICT.PVM.EFF.003	The implementation of patches must follow the formalized change process for the timely identification, prioritization, procurement, installation, and validation. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User

	Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Supplier Key References: ICT Risk Framework 1.0
25.3 DOR.ICT.PVM.EFF.004	The current patch levels of all systems must be compared against patch information from the vendor to support the assessment of the current level of risk. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Supplier Key References: ICT Risk Framework 1.0
25.4 DOR.ICT.PVM.EFF.005	Any new system and third-party software must be scanned for vulnerabilities and available patches and ensure it has up-to-date patches installed before connecting to DBAGs or the legal entity's environment according to protection need. In special cases, e.g. provisioning of notebooks, patches must be applied in a timely manner after connecting to DBAG or the legal entity's network. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0

ID: 26 (version 2.0)	Identification of patches
26 DOR.ICT.PVM.IDN.001	It must be ensured that as part of the patch management procedures, available patches are identified in a timely manner.
26.1 DOR.ICT.PVM.IDN.002	Available software and hardware patches and updates, which must be installed proactively, must be identified and evaluated using automated tools wherever possible, while end-of-life and unsupported software are treated as elevated risks and reported accordingly. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.10.4.a)
26.2 DOR.ICT.PVM.IDN.003	Infrastructure scanners should be able to scan and identify missing patches on all network devices (wired and wireless), servers, end user devices, mobile devices. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0

ID: 27 (version 2.0)	Testing and deployment of patches
27 DOR.ICT.PVM.PAP.001	It must be ensured that as part of the patch management procedures, patches are deployed properly.
27.1 DOR.ICT.PVM.PAP.002	To address identified vulnerabilities, within defined timelines, the deployment of patches and other mitigation measures must be prioritized following a risk-based approach based on the criticality of the vulnerability. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.10.2.f)
27.2 DOR.ICT.PVM.PAP.003	Prior to their deployment, patches and updates for software and hardware must be tested in accordance with the requirements laid out in the Software Development and ICT Change Management Guideline. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.10.3c)
27.3 DOR.ICT.PVM.PAP.004	Adequate measures must be in place for system integrity testing after patch deployment, including rollback plans in the event that system integrity testing fails. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0
27.4 DOR.ICT.PVM.PAP.005	The Asset Owners must, if possible, use tools that support centralized patch management capabilities and automated deployment of applicable patches. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0
27.5 DOR.ICT.PVM.PAP.006	During the patch processing within Change Management, the downloaded/delivered patch must be scanned for malware and the patch source is authenticated. The integrity of the patch must be confirmed before deployment (e.g. by verifying digital signature of the patch, hash signature comparison against the vendor publicly reported patch file hash and integrity-check). Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0

ID: 28 (version 2.0)	Exceptions for the deployment of patches
28 DOR.ICT.PVM.PAR.001	It must be ensured that exceptions for the deployment of patches are handled carefully, using a risk-based approach that considers the exposure and criticality of the vulnerability.
28.1 DOR.ICT.PVM.PAR.002	Where a patch implementation exception is required, a valid workaround to mitigate the associated vulnerabilities must be applied, if technically feasible. In cases where no such workaround or other mitigation measures can be applied, and no patch is expected to be released, a risk assessment should be conducted, and the replacement and disposal of the affected asset should be considered. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0
28.2 DOR.ICT.PVM.PAR.003	Any exception must be documented and maintained for audit purposes. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0
28.3 DOR.ICT.PVM.PAR.004	Any failure to implement a patch must be formally justified and approved by the responsible Asset Owner and the applicable Risk Owner⁶. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0

ID: 29 (version 2.0)	Remediation monitoring
29 DOR.ICT.PVM.REM.001	It must be ensured that the remediation of identified vulnerabilities is monitored.
29.1 DOR.ICT.PVM.REM.002	Every detected vulnerability affecting ICT Systems must be recorded and the remediation of vulnerabilities must be monitored and verified. Asset-Types: Business Process Key References: DORA RTS RMF A.10.2.g), A:10.2.h)

⁶ As outlined in the ICT Risk Management Guideline

ID: 30 (version 2.0)	Emergency management
30 DOR.ICT.PVM.EMR.001	It must be ensured that any vulnerability identified as an emergency is given special attention and that emergency procedures are in place to address it.
30.1 DOR.ICT.PVM.EMR.002	Vulnerabilities classified as “emergency” must follow defined vulnerability emergency management procedures, covering identified processes for the patching and updating of IT Assets. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.10.4.b)
30.2 DOR.ICT.PVM.EMR.003	The definition for emergency classification of vulnerabilities must at a minimum consider these criteria: - Whether a vulnerability that has been classified as “emergency” in the past is found again - The exploitability of the vulnerability - The technical impact of the vulnerability on relevant services and IT Assets, including supporting components - The exposure and criticality with regard to any of the protection goals of the affected or potentially affected IT Assets, including supporting components, and in particular affected critical or important functions (CIFs) Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8

ID: 31 (version 2.0)	Escalation management
31 DOR.ICT.PVM.ESC.001	It must be ensured that escalation procedures are in place and applied when vulnerabilities are not adequately addressed.
31.1 DOR.ICT.PVM.ESC.002	Escalation processes must be established as part of the defined vulnerability emergency management procedures which are applied in the following cases: - The vulnerability is not remediated within the given timeline, including failure to deploy patches and updates for software and hardware within the designated timeline - For exceptional cases where regular remediation according to the defined requirements is considered not possible Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
31.2 DOR.ICT.PVM.ESC.003	Overdue vulnerabilities must be followed up on a weekly basis. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8

ID: 32 (version 2.0)	Audit log
----------------------	-----------

32 DOR.ICT.PVM.LOG.001	An audit log must be kept for all steps undertaken in technical vulnerability management. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8
----------------------------------	--

ID: 33 (version 2.0)	Alignment with incident management activities
33 DOR.ICT.PVM.INC.001	The vulnerability management process must be aligned with the incident management process to enable information and data communication for relevant vulnerabilities to the incident response function in case an incident occurs. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.8

5. Roles and Responsibilities

5.1. Creator

The creator of the ICT Patch and Vulnerability Management Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of the ICT Patch and Vulnerability Management Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the ICT Patch and Vulnerability Management Guideline is Head of ICT Risk Governance & Advisory Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Chief ICT Risk Officer / CISO is responsible for publishing and updating the ICT Patch and Vulnerability Management Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner = Head of ICT Risk Governance & Advisory

Please contact ICT Risk Governance & Advisory in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	19.08.2026	Annual update with material changes

Coordination before publication

Version	Date	Task	Name
2.0	09.04.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	17.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	17.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
2.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	n/a

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
